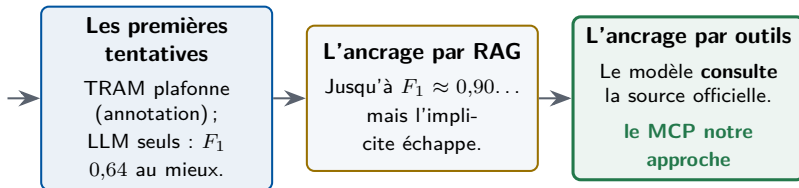

Intégration du framework MITRE ATT&CK dans un écosystème MCP pour la détection

Kamil Saleh

Superviseurs UQAC : Kevin Bouchard ■ Fehmi Jaafar

Superviseur Hydro-Québec : Franck Jeannot

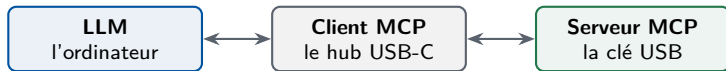
Le contexte : une IA brillante... qui ne dit jamais « je ne sais pas »



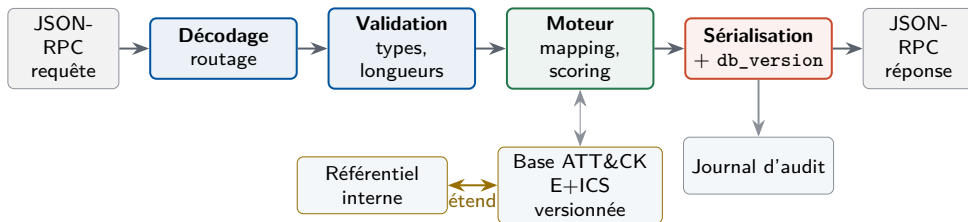
Capables, mais pas dignes de confiance seuls, la fiabilité tient à l'ancrage.

C'est quoi, le MCP ?

Le **Model Context Protocol** (MCP) : un standard ouvert (2024) qui branche un modèle d'IA sur une source de données par des appels tracés.



Notre serveur MCP : le trajet d'une requête



Le moteur : proposer, puis vérifier

search_techniques : **candidats scorés + preuves** → get_technique : **définition complète**
→ « **pas de mapping** » est valide.

Ce que ça rapporte à Hydro-Québec

Versionnage & mise à jour

La version **ATT&CK de notre choix**, chaque réponse datée ; le référentiel vivant suivi à la source, **sans réentraîner** de modèle.

Hallucination maîtrisée

Un identifiant retourné **existe forcément** dans la base. Ex. : T1086 révoquée → redirigée vers T1059.001.

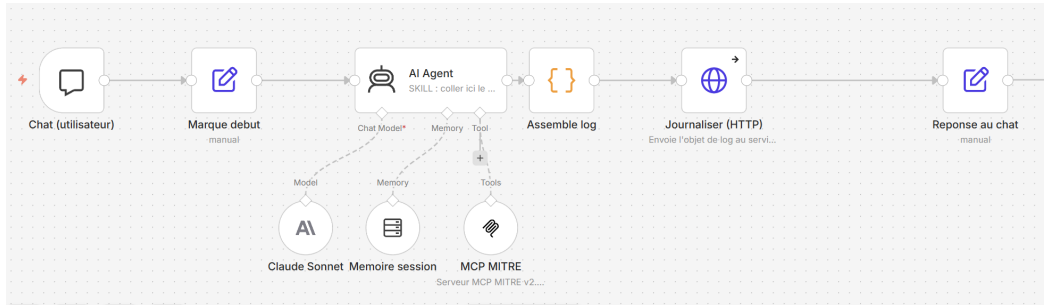
Customisation interne

Nos rapports red team et CTI avec des ID MITRE en Interne.

Polyvalence

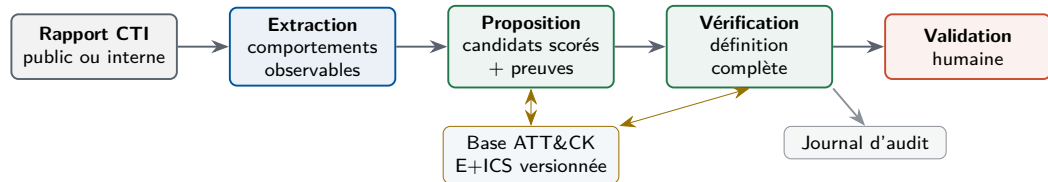
... Trois cas d'utilisation → les diapos suivantes.

Cas d'utilisation 1 : l'interface de chat n8n



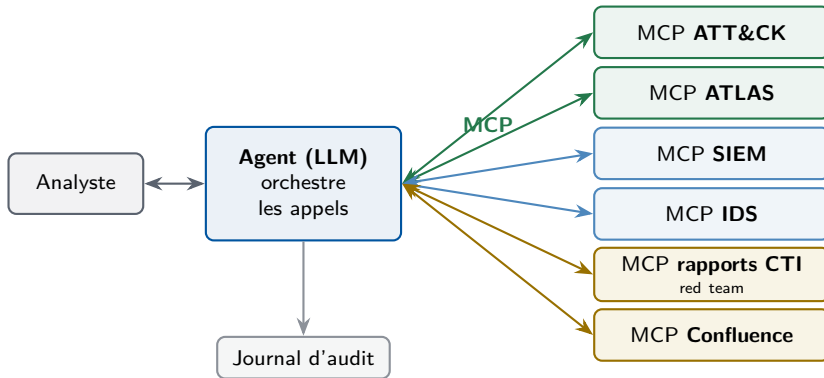
1 Question de l'analyste → **2** l'agent appelle le **serveur MCP MITRE** → **3** chaque appel **journalisé** → **4** réponse **sourcée et datée**.

Cas d'utilisation 2 : les rapports CTI



Des heures de lecture experte → quelques minutes de validation « pas de mapping » reste valide.

Cas d'utilisation 3 : un agent, plusieurs serveurs MCP



Le MCP : un outil mais aussi une surface d'attaque

Un LLM isolé qui se trompe produit du texte, branché à des outils, il peut produire une **action**.

Menace documentée

Empoisonnement d'outil

tool poisoning

Injection indirecte de prompt

indirect prompt injection

Accès non autorisé

unauthorized access

Action ou exfiltration non voulue

unintended action / exfiltration

Déni de service

denial of service

Perte de traçabilité

loss of auditability

Mesure à prévoir dans notre serveur

Descriptions figées et versionnées, intégrité vérifiée

Séparation données / instructions, validation des entrées

Authentification par jeton + chiffrement (TLS)

Lecture seule, moindre privilège

Limitation de débit

Journal d'audit : chaque appel et chaque refus

Questions ?
